
ZERO → JUNIOR SOC ANALYST

Полный путь от новичка до профессионального аналитика
Тёмная версия • Перевод на русский

автор: Amresh Kumar
github.com/Ak-cybe • linkedin.com/in/amresh-kumar-7b5ab8326

Эти заметки — полный роадмап от новичка до профессионального аналитика кибербезопасности.

Каждая тема объяснена простым языком с реальными примерами.

1. Читайте модули по порядку — каждый строится на предыдущем
2. Смотрите пример и пробуйте сами — практика обязательна
3. Изучайте связанные ресурсы, чтобы углубить знания
4. Делайте проекты — это самое важное для резюме
5. Решайте CTF-челленджи регулярно — навык приходит от практики

СОДЕРЖАНИЕ

01 Основы сетей и IT

TCP/IP, OSI, подсети, DNS, HTTP, фаерволы, Linux, Windows

02 Основы кибербезопасности

Триада CIA, типы атак, MITRE ATT&CK, логи, контроли

03 Скрипты и автоматизация

Bash, PowerShell, Python для безопасности

04 Домашняя лаборатория

VirtualBox, Kali, уязвимые BM, ELK Stack

05 SIEM — Splunk и ELK

Архитектура, SPL, Kibana, источники логов, triage

06 Реагирование на инциденты

Жизненный цикл PICERL, форензика, сдерживание

07 Анализ фишинга

Заголовки email, SPF/DKIM/DMARC, URL, IOC

08 Разведка угроз

OSINT, Shodan, фиды, профилирование акторов

09 EDR и анализ эндпоинтов

Инструменты EDR, дерево процессов, YARA

10 AI-проекты для SOC

AI-триаж, детектор фишинга, аномалии, Threat Intel Bot

11 Сертификации и карьера

Security+, CySA+, собеседования, зарплаты, CTF

12 Шпаргалки

Команды Linux, Nmap, порты, Event ID Windows

1 Основы сетей и IT

Как данные путешествуют по интернету? Мы используем многоуровневую модель. Две известные модели: OSI (7 уровней) и TCP/IP (4 уровня). В практике безопасности чаще используют TCP/IP.

Модель OSI (7 уровней)

- 7 — Прикладной — Протоколы приложений — HTTP, FTP, DNS, SMTP
- 6 — Представления — Кодирование/шифрование — SSL/TLS, JPEG, ASCII
- 5 — Сеансовый — Установка и поддержка соединения
- 4 — Транспортный — Доставка — TCP (надёжный), UDP (быстрый)
- 3 — Сетевой — Маршрутизация — IP-адреса, маршрутизаторы, ICMP
- 2 — Канальный — MAC-адреса, коммутаторы, кадры, ARP
- 1 — Физический — Кабели, Wi-Fi, биты как напряжения

Модель TCP/IP (4 уровня)

- Прикладной — HTTP, FTP, DNS, SMTP, SSH
- Транспортный — TCP = надёжный, 3-way handshake | UDP = быстрый, без подтверждения
- Интернет — IP-адресация, маршрутизация, ICMP
- Доступ к сети — Ethernet, Wi-Fi, MAC-кадры

TCP 3-Way Handshake

```
Клиент → SYN          → Сервер  (Можем поговорить?)
Клиент ← SYN-ACK       ← Сервер  (Да, я готов!)
Клиент → ACK           → Сервер  (Отлично, начинаем!)
```

Важно: При SYN Flood атаке злоумышленник засыпает сервер полуоткрытыми соединениями.

TCP = надёжный | UDP = быстрый (видео, DNS)

Порты: 80=HTTP, 443=HTTPS, 22=SSH, 21=FTP, 25=SMTP, 53=DNS

Используйте Wireshark, чтобы видеть пакеты своими глазами!

IP-адресация, подсети и CIDR

Каждое устройство в интернете имеет уникальный адрес. IPv4 — 32 бита: W.X.Y.Z (0-255). Всего ~4,3 млрд адресов.

- Класс A 1.0.0.0 - 126.x [/8] — ~16 млн хостов
- Класс B 128.0.0.0 - 191.x [/16] — ~65 000 хостов
- Класс C 192.0.0.0 - 223.x [/24] — 254 хоста
- Частные 10.x | 172.16-31.x | 192.168.x — не видны из интернета

Пример подсети

```
Дано: 192.168.1.0/24
Адрес сети      : 192.168.1.0
Маска          : 255.255.255.0
Широковещательный: 192.168.1.255
Диапазон хостов: 192.168.1.1 - 192.168.1.254

Разделение на /25:
Подсеть 1: 192.168.1.0/25   хосты .1-.126
Подсеть 2: 192.168.1.128/25 хосты .129-.254
```

Формула: $usable = 2^{(32 - prefix)} - 2$

/24=254 | /25=126 | /26=62 | /27=30 | /28=14 | /29=6 | /30=2

NAT: IPv4-адресов мало. Домашние устройства используют 192.168.x.x, роутер даёт один публичный IP. Атакующий не видит ваши частные адреса напрямую.

DNS, HTTP/HTTPS, DHCP, ARP

DNS — «телефонная книга» интернета. Вы вводите google.com, DNS превращает это в IP-адрес.

Процесс разрешения DNS

1. Браузер: www.google.com
2. ОС проверяет локальный кэш
3. Запрос к рекурсивному резолверу (DNS провайдера)
4. Root → .com TLD → авторитетный сервер Google

5. Ответ с IP → страница загружается (миллисекунды!)

Атаки: DNS Spoofing / Cache Poisoning, DNS Tunneling, DNS over HTTPS (DoH)

Методы HTTP и коды ответа

GET — запрос данных | POST — отправка | PUT — обновление | DELETE — удаление | HEAD — только заголовки

200 OK | 301/302 Redirect | 401 Unauthorized | 403 Forbidden | 404 Not Found | 500 Server Error

DHCP — процесс DORA

```
D — Discover   : Клиент: «Есть ли DHCP-сервер?»
O — Offer      : Сервер предлагает IP + время аренды
R — Request    : Клиент принимает IP
A — Acknowledge: Сервер подтверждает аренду
```

Атака: Rogue DHCP Server → фейковый шлюз → MITM

ARP

Знаете IP, нужен MAC? ARP рассылает в локальной сети: «Кто имеет 192.168.1.1?» Команда: **arp -a**

ARP Spoofing: Атакующий отправляет поддельные ARP-ответы → MITM

Файрволы, маршрутизаторы, коммутаторы, VLAN

Типы файрволов

- Packet Filter — только IP/порт/протокол, без состояния
- Stateful — отслеживает состояние соединения (самый распространённый)
- Application — инспекция на уровне 7
- NGFW — IPS + осведомлённость о приложениях + SSL-инспекция
- WAF — Web Application Firewall (только HTTP)

```
# Пример iptables (Linux)
iptables -A INPUT -m state --state ESTABLISHED,RELATED -j ACCEPT
iptables -A INPUT -p tcp --dport 80 -j ACCEPT
iptables -A INPUT -p tcp --dport 443 -j ACCEPT
iptables -A INPUT -j DROP # deny by default
```

Коммутатор (L2) — MAC-адреса, одна сеть, риск MAC flooding

Маршрутизатор (L3) — IP-адреса, соединяет сети, ACL для безопасности

VLAN — делит одну физическую сеть на логические (HR, Finance, IT). Преимущества: сегментация, контроль широковещания. Атака: VLAN Hopping.

Linux CLI

В Linux всё — файл. Файловая система — дерево от «/» (root).

```
pwd                # Текущая директория
ls -la             # Все файлы с правами
cd /var/log        # Смена директории
find / -name "*.log" # Поиск по системе
ps aux | grep nginx # Процессы
ss -tulnp          # Открытые порты
grep "Failed" /var/log/auth.log
cat auth.log | awk '{print $11}' | sort | uniq -c | sort -rn
```

Права: **-rwxr-xr--** → owner=rwx(7), group=r-x(5), others=r--(4)

chmod 755 script.sh | chmod 600 id_rsa

/etc = конфиги | /var/log = логи | /home = данные пользователей

Windows — PowerShell и Реестр

```
Get-Process
Get-Service | Where {$_.Status -eq "Running"}
Get-NetTCPConnection
Get-EventLog -LogName Security -Newest 50
Get-WinEvent -FilterHashtable @{LogName="Security"; Id=4625}
```

Ключевые ключи реестра

- HKLM\...\CurrentVersion\Run — автозапуск (проверяйте на malware!)
- HKCU\...\CurrentVersion\Run — программы при входе пользователя

- HKLM\SYSTEM\CurrentControlSet\Services — установленные службы

Важные Event ID Windows

- 4624 — Успешный вход
- 4625 — Неудачный вход — проверка brute force!
- 4688 — Создан новый процесс
- 4698 — Создана задача планировщика — persistence!
- 4720 — Создана учётная запись — backdoor?
- 7045 — Установлена новая служба — malware persistence!

Ресурсы: [Professor Messer TCP/IP](#) | [TryHackMe Pre-Security](#) | [subnettingpractice.com](#)

2 Основы кибербезопасности

Триада CIA

Три основных принципа кибербезопасности. Гарантированно встречается на экзамене Security+!

Конфиденциальность (Confidentiality) — доступ только у авторизованных

Как: шифрование, контроль доступа, аутентификация

Пример: база банка доступна только сотрудникам

Целостность (Integrity) — данные не изменены

Как: хеширование, цифровые подписи, контрольные суммы

Пример: скачали файл → проверили MD5-хеш

Доступность (Availability) — данные доступны когда нужны

Как: резервирование, бэкапы, защита от DDoS

Пример: медкарты должны быть доступны 24/7

Типы атак

Фишинг и его виды

- Phishing — массовая рассылка, «уважаемый клиент»
- Spear Phishing — целевой, исследуют конкретного человека/компанию
- Whaling — атака на топ-менеджмент (CEO/CFO)
- Vishing — голосовой фишинг | Smishing — SMS с вредоносной ссылкой

Типы malware

- Virus — распространяется от файла к файлу, нужен хост
- Worm — самораспространяется по сети
- Trojan — выглядит легитимно, содержит вредоносную нагрузку
- Ransomware — шифрует файлы, требует выкуп
- Spyware / Keylogger / Rootkit / RAT / Botnet

Атака MITM (Man-in-the-Middle)

Обычно: Клиент ↔ Сервер
MITM: Клиент ↔ Атакующий ↔ Сервер
Атакующий читает и может менять всё!

Методы: ARP Spoofing | SSL Stripping | Evil Twin WiFi

Защита: HTTPS везде, certificate pinning, VPN

Фреймворк MITRE ATT&CK;

База знаний реальных тактик, техник и процедур (TTP) атакующих. Аналитики SOC используют её для идентификации и сопоставления угроз. Сайт: attack.mitre.org

- TA0001 Reconnaissance — Сбор информации о цели
- TA0003 Initial Access — Первый вход (фишинг, эксплойт)
- TA0004 Execution — Запуск вредоносного кода
- TA0005 Persistence — Сохранение после перезагрузки
- TA0006 Privilege Escalation — Повышение привилегий
- TA0007 Defense Evasion — Обход защиты
- TA0008 Credential Access — Кража паролей/хешей
- TA0009 Discovery — Изучение окружения
- TA0010 Lateral Movement — Перемещение по сети
- TA0011 Collection — Сбор ценных данных
- TA0012 Command & Control — Связь с C2
- TA0013 Exfiltration — Вывод данных
- TA0014 Impact — Уничтожение/шифрование данных

Ransomware, сопоставленный с TTP

```
T1566.001 Spear phishing (Initial Access)
T1059.001 PowerShell execution (Execution)
T1547.001 Registry Run Key (Persistence)
T1055     Process Injection (Defense Evasion)
T1003.001 LSASS Credential Dump (Credential Access)
T1486     Data Encrypted for Impact (Impact)
```

Анализ логов

```
Jan 15 10:23:41 server01 sshd[1234]: Failed password for root from 192.168.1.100

# Поиск brute force
grep "Failed password" /var/log/auth.log | awk '{print $11}' | sort | uniq -c | sort -rn | head -10
```

Контроли безопасности

Preventive — предотвратить атаку (файрвол, шифрование, MFA, патчи)
Detective — обнаружить во время атаки (SIEM, IDS/IPS, антивирус)
Corrective — исправить после (бэкапы, план IR, патчи после инцидента)

Ресурсы: professormesser.com | [TryHackMe SOC Level 1](https://tryhackme.com/level/soc-level-1) | ATT&CK; Navigator

3 Скрипты и автоматизация

Умение кодить = x2 к зарплате! Автоматизируйте рутину — критически важно для аналитика.

Bash-скрипты

```
#!/bin/bash
NAME="SOC Analyst"
echo "Привет, $NAME!"
chmod +x script.sh && ./script.sh

for logfile in /var/log/*.log; do
    echo "Проверяю: $logfile"
    grep -c "ERROR" "$logfile"
done
```

PowerShell для безопасности

```
# Неудачные входы за 24 часа
$FailedLogins = Get-WinEvent -FilterHashtable @{
    LogName="Security"; Id=4625;
    StartTime=(Get-Date).AddHours(-24)
}
foreach ($event in $FailedLogins) {
    $xml = [xml]$event.ToXml()
    $ip = $xml.Event.EventData.Data[19]."#text"
    Write-Output "Неудачный вход с: $ip"
}
```

Python для безопасности

```
import re, socket, requests

def extract_ips(text):
    return re.findall(r"\b(?:\d{1,3}\.){3}\d{1,3}\b", text)

def port_scan(host, ports):
    open_ports = []
    for port in ports:
        sock = socket.socket(socket.AF_INET, socket.SOCK_STREAM)
        sock.settimeout(1)
        if sock.connect_ex((host, port)) == 0:
            open_ports.append(port)
        sock.close()
    return open_ports

print(port_scan("192.168.1.1", [21,22,80,443,3389]))
```

Ключевые библиотеки: requests, re, socket, yara, scrapy

4 Домашняя лаборатория

Нет лаборатории = только теория! Симулируйте атаки, используйте инструменты, учитесь на ошибках — без риска для реальных систем.

Требования: 8+ ГБ RAM (лучше 16), 100 ГБ SSD, 4+ ядра с VT-x/AMD-V.

```
# Архитектура лаборатории (Host-Only 192.168.56.0/24)
Хост
├── VirtualBox
│   ├── Kali Linux          [192.168.56.10] ← атакующий
│   ├── Metasploitable      [192.168.56.20] ← цель
│   ├── DVWA (Docker)       [192.168.56.30] ← веб-цель
│   ├── Windows Server      [192.168.56.40] ← Windows-цель
│   └── ELK Stack           [192.168.56.50] ← SIEM
```

Уязвимые VM: Metasploitable 2/3, DVWA, VulnHub (Mr. Robot, Kioptrix). Инструменты Kali: nmap, metasploit, burpsuite, wireshark, hydra, john, sqlmap, hashcat, gobuster.

ELK Stack (Docker)

```
version: "3"
services:
  elasticsearch:
    image: elasticsearch:8.5.0
    environment: [discovery.type=single-node]
    ports: ["9200:9200"]
  kibana:
    image: kibana:8.5.0
    ports: ["5601:5601"]
# docker-compose up -d → http://localhost:5601
```

5 SIEM — Splunk и ELK

Splunk = король рынка труда! SIEM = Security Information and Event Management. Центральная платформа: сбор логов, корреляция, оповещения. Сердце SOC.

Функции: Сбор логов → Нормализация → Корреляция → Алертинг → Дашборды → Отчёты → Threat Hunting

Архитектура Splunk

- Forwarder — сбор данных с источников
- Indexer — приём, парсинг, сжатие и хранение
- Search Head — интерфейс поиска и дашбордов

Ключевые источники логов

- Windows: Security.evtx — 4624/4625 (вход), 4740 (блокировка), 4688 (процесс)
- Linux: /var/log/auth.log, syslog — Failed password, sudo, cron
- Файрвол: allow/deny, NAT, гео-аномалии, паттерны DDoS
- Веб: access.log — попытки SQLi, сканеры, всплески 4xx/5xx
- EDR: создание процессов, изменения файлов/реестра, lateral movement

Фреймворк triage алертов

ШАГ 1 — Контекст: Кто? (IP/пользователь) | Когда? | Что? | Сколько раз?

ШАГ 2 — Базовая линия: Нормально ли это для пользователя? Необычное время?

ШАГ 3 — Pivot: Что после входа? Доступ к файлам? Lateral movement?

ШАГ 4 — Классификация:

TRUE POSITIVE → Реальная угроза → Эскалация в IR

FALSE POSITIVE → Легитимная активность → Документировать + настроить правило

BENIGN TP → Реально, но разрешено → Whitelist

6 Реагирование на инциденты

IR = самый высокооплачиваемый навык SOC! Структурированный подход к инцидентам. NIST SP 800-61 рекомендует модель PICERL.

1. Preparation (Подготовка) — План IR, инструменты, обучение, runbook'и.
2. Identification (Идентификация) — Обнаружение инцидента. SIEM, сообщения пользователей, threat intel.
3. Containment (Сдерживание) — Остановить распространение. Изолировать системы, сбросить креды.
4. Eradication (Устранение) — Удалить угрозу полностью. Удалить malware, закрыть уязвимость, найти backdoor'ы.
5. Recovery (Восстановление) — Вернуться к нормальной работе. Восстановить из чистого бэкапа, усиленный мониторинг.
6. Lessons Learned (Выводы) — Пост-инцидентное совещание. Что случилось? Как предотвратить? Обновить документацию.

Порядок волатильности (от самого к наименее)

- | | |
|----------------------------|---------------------------------------|
| 1. Регистры CPU / Кэш | (наносекунды – собирать ПЕРВЫМ) |
| 2. RAM / Память | (минуты – исчезает при перезагрузке) |
| 3. Сетевые соединения | (процессы, открытые сокетy) |
| 4. Запущенные процессы | (список процессов, DLL) |
| 5. Диск (файловая система) | (файлы – стабильны, но можно удалить) |
| 6. Бэкапы / Удалённые логи | (самые стабильные) |

Memory Forensics (Volatility)

```
volatility -f memory.raw imageinfo # Определить ОС
volatility -f memory.raw pslist    # Процессы
volatility -f memory.raw netscan   # Сетевые соединения
volatility -f memory.raw cmdline   # Командные строки
volatility -f memory.raw hashdump  # Хеши паролей
volatility -f memory.raw malfind    # Подозрительные регионы памяти
```

Сдерживание по типу инцидента

Ransomware: немедленно изолировать сеть → отключить сетевые диски → сбросить domain admin → проверить бэкапы

Скомпрометированный аккаунт: заблокировать → завершить сессии → аудит активности → включить MFA

Malware/Вторжение: сегментировать сеть → дампы памяти ПЕРВЫМ → форензик-образ → блокировать C2 IP/домен

7 Анализ фишинга

Email = вектор атаки №1! Заголовки письма фиксируют весь путь сообщения. Заголовки аутентификации — главный инструмент.

Ключевые поля заголовков

```
From: support@paypal.com ← проверка на SPOOF!
Reply-To: attacker@evil.com ← отличается от From?
Return-Path: bounce@random.ru ← подозрительный домен?
Received: from mail.evil.com ← исходный сервер
X-Originating-IP: 185.220.101.45 ← реальный IP отправителя
Subject: СРОЧНО: Подтвердите аккаунт ← социальная инженерия
```

SPF / DKIM / DMARC

SPF — проверяет, авторизован ли сервер отправки для домена. PASS / FAIL / SOFTFAIL

DKIM — цифровая подпись содержимого. PASS = подлинное и не изменено. FAIL = изменено или подделка.

DMARC — комбинирует SPF+DKIM. Политика: p=none | p=quarantine | p=reject (сильнейшая)

Вердикт: SPF=FAIL + DKIM=FAIL + DMARC=FAIL → почти наверняка фишинг!

Красные флаги URL

- Typosquatting: paypal.com, amazon.com, google.com
- Трюк с поддоменом: paypal.com.malicious.ru (TLD = .ru!)
- Сокращатели: bit.ly/xK9a2 → сначала развернуть!
- Homograph: кириллические символы, похожие на латиницу
- HTTP на странице логина = большой красный флаг

Инструменты: [virustotal.com](https://www.virustotal.com) | urlscan.io | checkphish.ai | any.run

Типы ИОС

Сетевые: IP, домен, URL, email

Хостовые: хеш файла (SHA256), путь, ключ реестра, mutex

Поведенческие: совпадение YARA, необычное дерево процессов, большой объем передачи

8 Разведка угроз (Threat Intelligence)

Знай врага до удара! OSINT = сбор разведданных из открытых источников.

Запросы Shodan

org:"Company Name"	→ устройства компании
hostname:company.com	→ поддомены
port:3389 country:RU	→ открытые RDP в России
vuln:CVE-2021-44228	→ серверы с Log4Shell
product:Apache httpd 2.4.49	→ конкретная уязвимая версия

Threat Feeds

- AlienVault OTX — сообщество, бесплатный API
- MISP — open-source платформа обмена угрозами
- Abuse.ch / Feodo Tracker — malware и C2 ботнетов (бесплатно)
- Emerging Threats — правила Suricata/Snort

Жизненный цикл TI: 1. Сбор → 2. Обработка → 3. Анализ → 4. Распространение
Diamond Model: Adversary → Capability → Infrastructure → Victim

9 EDR и анализ эндпоинтов

EDR = антивирус на стероидах! Детекция на основе поведения. Если что-то подозрительное происходит с процессами — EDR поднимает флаг.

Инструменты: CrowdStrike Falcon | SentinelOne | Microsoft Defender | Velociraptor (open source)

Красные флаги дерева процессов

НОРМАЛЬНО:

explorer.exe → chrome.exe
services.exe → svchost.exe

ПОДОЗРИТЕЛЬНО:

word.exe → powershell.exe	← макрос запускает PS!
powershell.exe → cmd.exe → net.exe	← команды разведки
excel.exe → wscript.exe	← VBA-дроппер!
svchost.exe → regsvr32.exe	← Living off the Land

Правила YARA

```
rule Mimikatz_Strings {
  strings:
    $s1 = "sekurlsa::logonpasswords" ascii wide
    $s2 = "lsadump::sam" ascii
    $s3 = "kerberos::list" ascii
  condition: 2 of ($s*)
}

rule Encoded_PowerShell {
  strings:
    $enc = "-EncodedCommand" nocase
    $byp = "-ExecutionPolicy Bypass" nocase
  condition: any of them
}
```

10 AI-проекты для SOC

Эти 4 проекта сделают ваше резюме заметным среди остальных.

Проект 1: AI-триаж SIEM

Проблема: сотни алертов в день → выгорание аналитиков. Решение: AI-ассистент делает первичный анализ и структурированный отчёт.

```
SIEM (Splunk/ELK) → JSON алерта → Python-скрипт → Claude/GPT API  
→ Структурированный отчёт (Severity, Attack Type, Actions, FP %)  
→ Аналитик смотрит summary → быстрее triage!
```

Проект 2: Детектор фишинга

Извлечение IOC regex'ом → проверка URL на VirusTotal → AI-анализ содержимого письма → вердикт + обоснование.

Проект 3: Детектор аномалий

```
from sklearn.ensemble import IsolationForest  
# Фичи: час, день недели, пользователь, source_ip  
model = IsolationForest(contamination=0.05)  
df["anomaly"] = model.fit_predict(features)  
# -1 = аномалия, 1 = норма
```

Проект 4: Threat Intel Bot

Обогащение в один клик: VirusTotal + AbuseIPDB + OTX → AI-сводка по IOC.

11 Сертификации и карьера

CompTIA Security+ (SY0-701)

Отраслевой стандарт для начального уровня. Требуется правительством США, военными и большинством компаний.

90 вопросов (MCQ + PBQ), 90 минут, проходной 750/900, ~\$392, действует 3 года.

Домены: Concepts 12% | Threats 22% | Architecture 18% | Operations 28% | Program Mgmt 20%

План на 30 дней: Неделя 1 — домены 1-2 | Неделя 2 — 3-4 | Неделя 3 — домен 5 + повтор | Неделя 4 — только practice exams. Стабильно 80%+ = готовы!

CySA+ (CS0-003)

Фокус: blue team, операции SOC, детекция угроз. Полезно после 3-6 месяцев опыта SOC. 85 вопросов, 165 минут.

Быстрые ответы на собеседовании

Что происходит при вводе URL? DNS → TCP 3-way → TLS → HTTP GET → ответ сервера → рендер

IDS vs IPS? IDS обнаруживает и алертит. IPS обнаруживает И блокирует (inline).

Как обработать фишинговое письмо? Анализ заголовков/URL/вложений → IOC → VirusTotal → блокировка → предупреждение → тикет → настройка правила

TCP vs UDP? TCP = надёжный, handshake. UDP = быстрый, без handshake (DNS, видео).

False Positive? Алерт сработал, но угрозы нет. Пример: авторизованный vulnerability scanner.

Зарплаты SOC Analyst (Индия, для ориентира)

L1 SOC Analyst (0-1 год):	3-6 LPA
L2 SOC Analyst (1-3 года):	6-12 LPA
L3 SOC Analyst (3-5 лет):	12-20 LPA
SOC Lead (5+ лет):	20-35 LPA
Security Architect (8+):	35-60+ LPA

Гид по CTF

Категории: Web, Pwn, Reverse, Crypto, Forensics, OSINT, Misc

Платформы: TryHackMe (новички) | HackTheBox | PicoCTF | CyberDefenders | Blue Team Labs Online | ctftime.org

Milestone CTF: THM Linux/Web Fundamentals, Splunk room, Phishing Analysis, PicoCTF Forensics, CyberDefenders REvil, BTL

Phishing Response, HTB Starting Point

12 Шпаргалки

Основные команды Linux

```
ls -la | pwd | cd | mkdir | rm -rf | cp | mv | find | locate
cat | less | head | tail -f | grep -r | grep -v
whoami | id | sudo | chmod 755 | chown | passwd
ip a | ss -tulpn | ping | traceroute | nmap -sV | curl | wget
tcpdump -i eth0 -w cap.pcap
```

Частые сканы Nmap

```
nmap 192.168.1.0/24          # Обнаружение хостов
nmap -sV -sC target.com      # Версии + скрипты
nmap -A -T4 target.com       # Агрессивный (OC + сервисы)
nmap -p 80,443,22,3389 target # Конкретные порты
nmap -p- target              # Все 65535 портов
nmap --script vuln target     # Скрипты уязвимостей
```

Критические порты

- 21 FTP — цель brute force
- 22 SSH — цель brute force
- 23 Telnet — нешифрованный — НИКОГДА в production
- 25 SMTP — релей фишинга
- 53 DNS — вектор туннелирования
- 80/443 HTTP/S — веб-атаки
- 139/445 SMB — EternalBlue, WannaCry
- 3389 RDP — brute force!
- 1433/3306/5432 БД — SQL Server / MySQL / Postgres
- 5985 WinRM — lateral movement

Ключевые Event ID Windows

- 4624 — Успешный вход
- 4625 — Неудачный вход — brute force
- 4648 — Вход с явными credentials
- 4688 — Создан новый процесс
- 4698 — Создана задача планировщика — persistence
- 4720 — Создана учётная запись — backdoor?
- 4740 — Блокировка аккаунта — spray attack?
- 7045 — Установлена новая служба

Рoadmap на 12 месяцев

- Месяц 1–2: Сети — TCP/IP, подсети, DNS, Linux CLI
- Месяц 2–3: Основы кибербезопасности + Bash/Python
- Месяц 3: Домашняя лаборатория + первые CTF на TryHackMe
- Месяц 3–4: Изучение Security+ → сдача экзамена
- Месяц 5: SIEM — Splunk + ELK + лаборатории по фишингу
- Месяц 6: Лаборатории IR на CyberDefenders
- Месяц 7: Threat Intel + EDR + правила YARA
- Месяц 7–8: 4 AI-проекта на GitHub
- Месяц 9: Изучение CySA+ → сдача экзамена
- Месяц 10+: Отклики на Junior SOC Analyst!

Чеклист перед откликами: Security+ сдан • Лаборатория работает • GitHub с 4+ проектами • TryHackMe SOC Level 1 пройден • 10+ CTF решено • LinkedIn обновлён • Резюме заточено под SOC

Эти заметки — первый шаг вашего пути.
Теперь идите, стройте, ломайте и учитесь.

— Amresh Kumar | github.com/Ak-cybe —

Перевод на русский: тёмная cyber-версия